



בדיקת אבטחה – מערכת הניהול של גן החלומות

מסמך הרצה · 07.10.2026

המסמך הזה נכתב בשביל בודק חוץ. הוא נותן לך את כל מה שצריך כדי לתקוף את המערכת מבלי לבזבז זמן על מיפוי: מה היא עושה, על מה היא יושבת, איך מזדהים בה, איפה הנתונים הרגישים, מה כבר נבדק, ומה אנחנו באמת מפחדים ממנו.

1. מה המערכת עושה

מערכת ניהול לרשת גני ילדים – עמותת גן החלומות (ע"ר) 580757805. כמה סניפים, כ-230 ילדים פעילים, כ-110 חשבונות צוות.

מה יש בה, בגדול:

- **תיק הילד** – פרטים, ת"ז, תאריך לידה, כתובת, אלרגיות, מצבים רפואיים, אנשי קשר לחירום, מי מורשה לאסוף.
- **רישום וחוזים** – טפסי רישום ציבוריים בקישור, חתימה דיגיטלית, חוזה PDF.
- **גבייה** – שכר לימוד, הנחות, חובות, מצב תשלום לכל חודש לכל ילד.
- **שכר ונוכחות** – שעוני נוכחות ביומטריים בסניפים, תלושי שכר, טופס 101, תיק העובד (תעודות, אישורים, מסמכים סרוקים).
- **תמונות** – צילומים של ילדים, כולל זיהוי פנים לתיג.
- **פורטל הורים** – הורה נכנס, רואה את ילדיו, את החוזה, את התשלומים ואת התמונות שלהם.
- **לוח כיתה** – טאבלט על קיר החדר, מציג את החדר ההוא בלבד.
- **לוח דרושים ציבורי** – שירות נפרד לגמרי.

2. קישורים

מה	איפה
קוד המערכת	https://github.com/tofyproductions/gan-halomot
המערכת החיה	https://gan-halomot.onrender.com
בדיקת בריאות	https://gan-halomot.onrender.com/api/health
שירות הדמו / הפלטפורמה	https://ganflow.onrender.com
לוח הדרושים	https://jobgan.onrender.com
סקירת אבטחה קודמת	בשורש הריפוי SECURITY_REVIEW_2026-09-03.md
הקשר לקוד	HALOM_RUNBOOK.md , CLAUDE_CONTEXT.md

גישת קריאה לריפוי ולחשבון Render תימסר לך בנפרד, לא במסמך הזה.

3. על מה זה רץ

שכבה	ספק	מה חשוב לדעת
אירוח השרת	Render, אזור פרנקפורט, מסלול חינמי	שלושה שירותים מאותו ריפוי. העלאה אוטומטית מ- <code>origin/main</code>
מסד נתונים	MongoDB Atlas	שם ה-cluster יימסר בנפרד. Mongoose 8
אחסון קבצים	Cloudflare R2	הדלי פרטי. קריאה רק דרך קישור חתום קצר-מועד שנוצר לכל בקשה
הודעות SMS	SMS4Free	קוד כניסה להורים ולצוות, איפוס סיסמה, הודעות דחופות
דואר יוצא	Google Apps / Gmail SMTP / Resend Script	שלושה מסלולים, מי שמוגדר הוא שעובד
דחיפת התראות	Firebase FCM (אפליקציה) + Web Push עם VAPID (דפדפן)	
בינה מלאכותית	Anthropic API	סריקת אישורי מחלה בלבד. בלי מפתח - המסלול מחזיר 501
גוגל	Google Sheets API	סנכרון דו-כיווני. כותב לגיליונות
הנהלת חשבונות	iCount API	הוצאות וספקים
יבוא חיצוני	Cibus, ClickTac	לשניהם אין API. רובוט מוריד דוחות ושולח קבצים ל- <code>/api/import-bot</code>
שעוני נוכחות	Raspberry Pi בכל סניף + שעון TIMEDOX TANDEM4 PRO	הסוכן מצביע החתמות לשרת כל 15 שניות
נקודת כניסה חלופית	Vercel	<code>api/index.js</code> - אותו קוד שרת, עטיפה אחרת
בקרת גרסאות	GitHub, <code>tofyproductions/gan-halomot</code>	

מה שחשוב להבין על ההפרדה בין השלושה: `gan-halomot` הוא הגן האמיתי. `ganflow` הוא דמו עם נתונים מעורבלים ושכבת פלטפורמה רדומה. `jobgan` הוא לוח דרושים ציבורי עם מסד נתונים נפרד, מפתח חתימה נפרד ונקודת כניסה נפרדת. יש שומרים בקוד שמסרבים לעלות אם שם המסד לא תואם - שווה לבדוק אם אפשר לעקוף אותם.

4. איך מזדהים – שמונה דרכים שונות

זה המקום הכי מעניין במערכת, כי יש בו **שמונה** מנגנוני זיהוי נפרדים, וכל אחד מהם הוא דלת.

צוות

שם מלא + ת"ז ← קוד בן 6 ספרות ב-SMS לנייד **שרשום אצלנו** ← בחירת סיסמה אישית ← הצעה להוסיף זיהוי ביומטרי (WebAuthn). מהכניסה הבאה: סיסמה או טביעת אצבע.

שונה היום, 07.10.2026. עד הבוקר שם + ת"ז לבד הנפיקו סשן מלא לכל חשבון שלא נבחרה בו סיסמה – 60 מתוך 73 חשבונות פעילים. זה נסגר. אם אתה מוצא מסלול שעוד מנפיק אסימון בלי קוד – זה הדבר הראשון שנרצה לשמוע.

הטוקן: JWT חתום ב-JWT_SECRET. תוקף 24 שעות, או 30 יום עם "זכור אותי", או 180 יום ללוח כיתה. נשמר ב-localStorage. **אין רשימת ביטול.**

הורים

ת"ז של ההורה או של **אחד מילדיו** ← קוד ב-SMS לנייד שרשום בגן ← סיסמה ← אופציונלית passkey.

- מספר של ילד נפתר אל ההורה, לא הופך לזהות בעצמו.
- ת"ז של הורה נבדקת תמיד ראשונה ומנצחת.
- ליילד עם שני הורים רשומים – נשאלים מי מדבר, מוצגים שם פרטי ונייד ממוסך, והבחירה חוזרת כאסימון חתום קצר-מועד. ת"ז ההורה לא מגיעה לדפדפן.
- הטוקן של ההורה חתום במפתח אחר** – נגזרת HMAC של JWT_SECRET. זה מכוון: טוקן הורה נכשל באימות חתימה בצד הצוות ולהפך. תוקף 30 יום, בלי רשימת ביטול.

ששת האחרים

מי	איך
לוח כיתה	טוקן בקישור + כניסה. רואה חדר אחד
סוכני ה-Pi	סוד משותף, השוואה בזמן קבוע
רובוט היבוא	IMPORT_BOT_SECRET, כתיבה בלבד, שני מסלולים. בלי המפתח – 503
חלון קריאה חיצוני ("המוח")	BRAIN_READ_KEY, GET בלבד. בלי המפתח – 503
סוכן כספים	מפתח משותף חתום
קונסולת הפלטפורמה	PLATFORM_JWT_SECRET – לא אותו מפתח, בכוונה

מסלולים ציבוריים לגמרי (בלי שום התחברות)

כ-20 כתובות תחת `/api/public` - טופס רישום לפי טוקן, חתימת חוזה, חוזה העסקה, בחירת פריטים באירוע, הגשת מועמדות עם קובץ CV, טפסי לידיים, הרשמת עובד. רובם מוגנים בטוקן `uuidv4` **בנתיב ה-URL**. זו רשימה שכדאי לעבור עליה אחת-אחת.

5. ההרשאות

תשעה תפקידים:

מה הוא	תפקיד
מנהל מערכת	<code>system_admin</code>
מנהל מערכת לצפייה בלבד	<code>admin_viewer</code>
מנהל סניף	<code>branch_manager</code>
הנהלת חשבונות	<code>accountant</code>
גננת אחראית	<code>class_leader</code>
גננת	<code>teacher</code>
סייעת	<code>assistant</code>
מבשלת	<code>cook</code>
לוח כיתה	<code>classroom_board</code>

הנקודה הרגישה ביותר במערכת: גבול הסניף. יש מנגנון נכון בשרת (`resolveBranchScope`) ב- `utils/branch-scope.js`, `getBranchFilter` ב- `utils/branch-filter.js`, `attachBranchScope` ב- `middleware/auth.js`, והוא בשימוש ב-31 מתוך 94 ה-`controllers`. בסקירה של ספטמבר הוא היה בשימוש בארבעה. חלק מה-63 הנותרים לא אמורים להיות מסונני-סניף בכלל (הגדרות, התחברות). חלק כן. אנחנו לא יודעים בוודאות אילו, וזה בדיוק מה שאנחנו רוצים שתמצא.

82 קובצי מסלולים, כ-94 `controllers`.

6. הנתונים הרגישים – מה יכאב אם ייחשף

לפי סדר, הכי כואב קודם:

1. מצבים רפואיים ואלרגיות של ילדים - `Child.allergies`, `Child.medical_alerts`. מידע רפואי על מישהו אחר, בן שלוש.
2. ת"ז של ילדים - `Child.child_id_number`. 161 מ-227 הילדים הפעילים.
3. ת"ז של הורים ושל עובדות - `Child.parent_id_number`, `Registration.parent_id_number`, `User.id_number`, `Employee.israeli_id`.
4. תמונות של ילדים - ב-R2, כולל וקטורי זיהוי פנים.
5. תלושי שכר ותיק העובד - `DirectPayslipBatch`, `Form101Inbox`, `EmployeeDocument`, `SavedPayslip`. כולל מסמכים סרוקים.
6. גבייה - מי חייב כמה, מי קיבל הנחה ולמה.
7. חוזים חתומים - של משפחות ושל עובדות.
8. טלפונים וכתובות של כל המשפחות ושל כל הצוות.

כל הקבצים האלה יושבים ב-R2 בדלי פרטי. המסד שומר רק את המפתח, והקריאה היא קישור חתום שנוצר לכל בקשה. **בדוק את זה.** אם קישור חתום לא נבדק מול ההרשאה של מי שביקש אותו - זה חור.

7. מה שכבר נבדק - אל תבזבז על זה זמן

נמצא ותוקן (ספטמבר-אוקטובר 2026)

- גבול הסניף נאכף בשרת, ולא רק אם הלקוח ביקש.
- בדיקת בעלות בכל קריאה ופעולה לפי מזהה - ילדים, מסמכים, חוזים.
- `JWT_SECRET` - השרת מסרב לעלות ב-production בלי המשתנה.
- הזרקת קוד (XSS) בחוזים ובייצוא PDF.
- הגבלת קצב על כל מסלולי ההתחברות.
- CORS - רשימת היתר, לא `*`. גם בנקודת Vercel.
- אימות `month` לפני שהוא נכנס ל-`$regex` (היה DoS).
- PDF אנשי קשר מסונן לסניף.
- מזהה תמונה ישר מה-URL - הורה הדביק את ילדו לתמונה מסניף אחר וראה אותה.
- שרשרת השתלטות דרך "הוספת הורה נוסף" - ניתוב קוד כניסה של הורה אחר לנייד שהוקלד.
- `authMiddleware` שלא בדק `typ` - טוקן בצורת הורה חתום במפתח הצוות נכנס לכל מסלול צוות בלי שומר תפקיד.
- שם + ת"ז בתור אמצעי התחברות (היום).
- 91 חשבונות ששמרו את הת"ז שלהם כגיבוב הסיסמה. לא נפתח איתם שום דבר, אבל המלכודת הוסרה.

ידוע פתוח – אתה מוזמן לאשר, לתעדף ולהראות ניצול

- טוקן חי 30 יום בלי רשימת ביטול. חשבון שנסגר – הטוקן שלו עוד עובד.
- טוקן ב- `localStorage`, ו-CSP בלי `script-src`. ההגנות הקיימות הן `object-src`, `frame-ancestors`, `base-uri`, `form-action`. בלבד.
- מניית ת"ז במסך הכניסה – מספר שאינו רשום נענה בפירוש. החלטה מכוונת לגן בודד, ששווה חשיבה מחדש.
- רוב מסלולי הגאנט בלי שומר תפקיד – צוות מול צוות.
- כפילות מספרי טלפון בין חשבונות הורים.
- תלויות עם CVE: `xlsx@0.18.5` (prototype pollution, ReDoS) – אין תיקון בקו (npm), `multer@1.4.5` (DoS) – טוקן ב-X.2).
- `morgan('combined')` ב-`production` – מה בדיוק נכנס ללוגים.
- העלאת קבצים בלי `fileFilter` – סוג התוכן לא מאומת.
- טוקני `uuidv4` בנתיב URL במסלולים הציבוריים – לוגים, `Referer`, היסטוריה.
- הודעות שגיאה גולמיות מוחזרות ללקוח (ה-stack מוסתר ב-`production`).

מה שנבדק ונמצא תקין

הפרדת המפתחות בין טוקן הורה לטוקן צוות; בדיקת שיוך-לקוח בטוקן; אימות סוכני Pi בזמן קבוע; חסינות ההתחברות מהזרקת NoSQL; אין סודות בהיסטוריה ה-git; `render.yaml` עם `sync: false` לכל סוד; אין `command injection`; אין SSRF (כל קריאה יוצאת לכתובת קבועה); `/me` מסיר את גיבוב הסיסמה; `bcrypt cost 10`.

8. מה הכי חשוב לנו שתבדוק

לפי סדר העדיפות שלנו:

1. האם הורה יכול להגיע למשהו שאינו שלו? ילד של משפחה אחרת, תמונה של חדר אחר, חוזה של מישהו אחר, מסמך לפי מזהה. יש בדיקה אוטומטית (`npm run test:parent-authz`, 42 בדיקות) שקוראת את טבלת המסלולים מתוך `parent.routes.js` – נסה לעקוף אותה.
2. האם הורה יכול להפוך לצוות? או טוקן צוות להיכנס לפורטל ההורים.
3. האם גננת בסניף א' רואה סניף ב'? זה היה החור הגדול, הוא תוקן בשורש, ו-63 controllers עוד לא קוראים למנגנון.
4. האם אפשר להיכנס בלי קוד ה-SMS? המסלול החדש מהבוקר. כולל: טביעת אצבע, איפוס סיסמה, `login-password`, קונסולת הפלטפורמה, לוח הכיתה.
5. האם אפשר לנתב קוד SMS לנייד שלא שלנו? כל מקום שמקבל מספר טלפון בבקשה.
6. האם קישור חתום ל-R2 נבדק מול ההרשאה של המבקש? כולל תמונות של ילדים ומסמכים של עובדות.
7. 20 המסלולים הציבוריים – מה אפשר לעשות עם טוקן שנוחש, שדלף או שנותר בהיסטוריה.
8. ההפרדה בין שלושת השירותים – האם אפשר לגרום ל-`jobgan` או ל-`ganflow` לדבר עם המסד של הגן.

9. רובוט היבוא וסוכני ה-Pi – מה אפשר לדחוף פנימה עם, ובלי, המפתח.

10. העלאת קבצים – מה אפשר להעלות ומה קורה אחר כך.

9. כלל ההתנהגות

מה מותר: לקרוא את כל הקוד. לתקוף את המערכת החיה מהחשבונות שתקבל. לנסות להגיע לנתונים שהחשבון שלך לא אמור לראות ולתעד שהגעת.

מה אסור:

- לא למחוק ולא לשנות נתונים אמיתיים. אם הוכחת כתיבה – לתעד ולעצור.
 - לא להוציא נתונים אמיתיים מהמערכת. לא להוריד קבצים של ילדים או של עובדות למחשב שלך. אם צריך להראות חשיפה – צילום מסך של רשומה אחת, ממוסך.
 - לא להפיל את השירות. המסלול החינמי ב-Render הוא מכונה אחת, וגן שעובד עכשיו תלוי בה. אם מצאת DoS – תאר אותו, אל תריץ אותו.
 - לא לשלוח SMS או דואר בכמות. המאזן בתשלום מראש, וכל הודעה מגיעה לטלפון של הורה אמיתי.
 - לא לגעת בשעוני הנוכחות בסניפים.
- איך לדווח:** כל ממצא בנפרד – מה מצאת, איפה (נתיב קובץ ושורה, או כתובת), איך לשחזר צעד-צעד, מה הנזק הממשי, ומה ההמלצה. חמורות – להרים טלפון מיד, לא לחכות לדוח.
- המידע כאן חסוי.** המסמך מתאר את כל מערכות ההגנה של גן עם 230 ילדים.

10. החשבונות שתקבל

מה	פרטים יימסרו בנפרד
גישת קריאה לריפו ב-GitHub	
חשבון <code>system_admin</code> במערכת החיה	על שמך, מסומן כחשבון בדיקה
חשבון הורה במערכת החיה	מקושר למשפחת בדיקה
גישת צפייה ל-Render	אם צריך לוגים

החשבונות ייפתחו על שמך, לזמן מוגבל, וייסגרו בסוף הבדיקה. אין חשבונות משותפים – כדי שכל פעולה ביומן תהיה שלך ונדע להבדיל בינה לבין משהו אחר.

הערה: החשבונות הם על המערכת **האמיתית**, עם נתונים אמיתיים של ילדים אמיתיים. זו בחירה מכוונת כדי שתבדוק את מה שקיים ולא העתק שלו – ולכן הכלל על אי-הוצאת נתונים הוא הכלל החשוב במסמך הזה.

11. לטל

היי טל,

המערכת שתקרא עליה כאן מנהלת רשת גני ילדים – כ-230 ילדים וכ-110 עובדות. היא נבנתה מהר, היא עושה הרבה, והיא מחזיקה בדיוק את סוגי המידע שאני הכי לא רוצה שייחשפו: מה הילד אלרגי אליו, מה ת"ז שלו, איך נראה התלוש של הגננת, ומי חייב כסף.

עשינו שתי סקירות קוד פנימיות ותיקנו הרבה. מה שלא עשינו זה להביא מישור מבחן שינסה באמת להיכנס. לזה אתה כאן. מה שאני מבקש ממך בפירוש: **אל תחפש את מה שכבר מצאנו**. סעיף 7 הוא רשימה כפולה – מה תוקן, ומה ידוע פתוח. אם משהו ברשימת "תוקן" לא באמת תוקן, זה ממצא מעולה ואני רוצה לדעת מיד. אם משהו ברשימת "פתוח" מנוצל יותר גרוע ממה שחשבנו, גם זה. אבל הדבר שאני באמת קונה ממך הוא מה שאף אחד מאיתנו עוד לא העלה בדעתו. סעיף 8 הוא סדר העדיפויות שלי, ואתה מוזמן לא להסכים איתו. אם אתה חושב שהזמן שלך שווה יותר במקום אחר – תגיד לי ונדבר.

שני דברים שאני מבקש לקחת ברצינות. אחד: החשבונות שתקבל הם על המערכת החיה, עם נתונים של ילדים אמיתיים. סעיף 9 מפרט, והשורה התחתונה היא שאפשר להוכיח חשיפה בלי להוציא את הנתונים מהמערכת. שתיים: הגן עובד עכשיו. אם מצאת משהו שמפיל את השירות, תאר אותו במקום להריץ אותו – אני אאמין לך.

אם משהו במסמך לא מדויק או חסר – תשאל. עדיף שתשאל מאשר שתנחש.

תודה שאתה נכנס לזה, עמית

עמותת גן החלומות (ע"ר) 580757805 · 052-3866819 · tofy10.office@gmail.com